

Segurança e Autorização em Banco de Dados

Esta unidade aborda as técnicas utilizadas para proteger o banco de dados contra pessoas que não estão autorizadas a acessar determinadas partes ou todo o banco de dados. A Seção 6.1 apresenta uma introdução às questões de segurança e às ameaças aos bancos de dados e uma visão geral das medidas que são objeto de estudo desta unidade. A Seção 6.2 discute os mecanismos utilizados para conceder e revogar privilégios em sistemas de bancos de dados relacionais e em SQL, mecanismos que freqüentemente são chamados de **controle de acesso discricionário**. A Seção 6.3 oferece uma visão geral dos mecanismos que implementam níveis múltiplos de segurança, uma preocupação mais recente de segurança em banco de dados que é conhecida por **controle de acesso obrigatório (mandatory)**. A Seção 6.4 é um breve sumário dos esquemas de infra-estrutura de criptografia (ou cifração) e de chave pública.

6.1 INTRODUÇÃO ÀS QUESTÕES DE SEGURANÇA EM BANCOS DE DADOS

6.1.1 Tipos de Segurança

A segurança em bancos de dados é uma área bastante ampla que se refere a muitas questões, incluindo:

- Questões legais e éticas referentes ao direito de acesso a certas informações. Algumas informações podem ser consideradas privadas e não podem ser acessadas legalmente por pessoas não autorizadas. Nos Estados Unidos, existem diversas leis que disciplinam a privacidade de informações.
- Questões políticas nos níveis governamental, institucional ou corporativo, como quais os tipos de informação que não devem ser tornadas disponíveis publicamente. Por exemplo, avaliações de crédito e registros médicos pessoais.
- Questões relacionadas ao sistema, como os *níveis de sistema* nos quais as várias funções de segurança devem ser implementadas. Por exemplo, se uma função de segurança deve ser tratada no nível físico de hardware, no nível de sistema operacional ou no nível do SGBD.
- As necessidades em algumas organizações de identificar múltiplos *níveis de segurança* e em categorizar os dados e usuários com base nessas classificações. Por exemplo, altamente secreto (*top secret*), secreto (*secret*), confidencial (*confidential*) e não confidencial (*unclassified*). A política de segurança de uma

organização a respeito da permissão de acesso a várias classificações de dados deve ser implementada.

Ameaças aos Bancos de Dados. As ameaças aos bancos de dados resultam na perda ou na degradação de alguns ou de todos os seguintes objetivos de segurança: integridade, disponibilidade e confidencialidade.

- *Perda de integridade:* A integridade do banco de dados refere-se à exigência de que a informação seja protegida contra a modificação imprópria. A modificação de dados inclui a criação, a inclusão, a alteração, a mudança de *status* do dado e a exclusão. A integridade é perdida se modificações não autorizadas são realizadas nos dados tanto por atos intencionais quanto por atos acidentais. Se a perda de integridade do sistema ou dos dados não for corrigida, o uso prolongado do sistema contaminado ou de dados corrompidos pode resultar em imprecisão, fraude ou em decisões equivocadas.

- *Perda de disponibilidade:* A disponibilidade de banco de dados refere-se a tornar os objetos disponíveis para um usuário humano ou para um programa que tenham direito legítimo a eles.

- *Perda de confidencialidade:* A confidencialidade de um banco de dados refere-se à proteção dos dados contra a divulgação não autorizada. O impacto da divulgação não autorizada de informação confidencial pode variar desde a violação da *Data Privacy Act* (Lei de Privacidade de Dados, nos Estados Unidos) até a colocação em risco da segurança nacional. A divulgação não autorizada, imprevista, ou não intencional pode resultar na perda da confiança pública, em constrangimentos, ou na ação legal contra a organização.

Para proteger o banco de dados contra esses tipos de ameaças, alguns tipos de medidas podem ser implementadas: controle de acesso, controle de inferência e criptografia. Discutimos todas nesta unidade.

Em um sistema de banco de dados multiusuário, o SGBD deve oferecer técnicas que habilitam certos usuários ou grupos de usuários a acessar partes selecionadas de um banco de dados sem obter acesso ao restante do banco. Isso é especialmente importante quando um grande banco de dados integrado é utilizado por muitos usuários diferentes dentro de uma mesma organização. Por exemplo, informações sensíveis, como salários de funcionários ou avaliações de desempenho, devem ser tidas confidencialmente em relação à maioria dos usuários do sistema de banco de dados. Tipicamente um SGBD inclui um subsistema de segurança de banco de dados e de autorização que é responsável por garantir a segurança de partes de um banco de dados contra o acesso não autorizado. Atualmente é comum se referir a dois tipos de mecanismos de segurança de bancos de dados:

- *Mecanismos de acesso discricionário:* São utilizados para conceder privilégios a usuários, inclusive a capacidade de acessar arquivos de dados, registros ou campos específicos de uma maneira específica (como leitura, inclusão, exclusão ou atualização).

- *Mecanismos de acesso obrigatório (mandatory):* São utilizados para impor a segurança em vários níveis por meio da classificação dos dados e dos usuários em várias classes de segurança (ou níveis) e, depois, pela implementação da política de segurança adequada da organização. Por exemplo, uma política de segurança típica é permitir aos usuários em determinado nível da classificação verem apenas os itens de dados

classificados no próprio nível de classificação do usuário (ou abaixo). Uma extensão disso é a *segurança baseada em papéis (role-based)*, que impõe políticas e privilégios baseando-se no conceito de papéis.

Veremos a segurança discricionária na Seção 6.2, e a segurança obrigatória e a baseada em papéis na Seção 6.3.

Um segundo problema comum a todos os sistemas de computação é prevenir que pessoas não autorizadas acessem o próprio sistema, seja para obter informação, seja para realizar alterações mal-intencionadas em uma parte do banco de dados. O mecanismo de segurança de um banco de dados deve incluir providências para a restrição de acesso ao sistema de banco de dados como um todo. Essa função é chamada **controle de acesso** e é tratada por meio da criação de contas de usuários e senhas para controlar o processo de *login* pelo SGBD. Veremos as técnicas de controle de acesso na Seção 6.1.3.

Uma última questão de segurança é a criptografia de dados, utilizada para proteger dados sensíveis (como números de cartões de crédito) que estão sendo transmitidos por meio de alguma rede de comunicação. A criptografia também pode ser usada para prover proteção adicional para as partes sensíveis de um banco de dados. Os dados são codificados utilizando algum algoritmo de codificação. Um usuário não autorizado que acesse os dados codificados terá dificuldades em decifrá-los; já aos usuários autorizados são fornecidos algoritmos de decodificação ou de decifragem (ou chaves) para esses dados. Técnica criptografia que são muito difíceis de serem decodificadas sem uma chave têm sido desenvolvidas para aplicações militares. A Seção 6.4 discute brevemente as técnicas de criptografia, incluindo técnicas populares, como criptografia de chave pública, que é muito utilizada para dar apoio a transações de bancos de dados baseadas na Web, e as assinaturas digitais, que são utilizadas nas comunicações pessoais.

6.1.2 Segurança de Banco de Dados e o DBA

O administrador do banco de dados (DBA) é a autoridade principal para o gerenciamento de um sistema de banco de dados. As responsabilidades do DBA incluem a concessão de privilégios a usuários que precisam utilizar o sistema e a classificação de usuários e dados de acordo com a política da organização. O DBA possui uma **conta de DBA** no SGBD, às vezes chamada **conta de sistema** ou **de superusuário**, que habilita capacidades que não estão disponíveis para as contas e usuários comuns do banco de dados. Os comandos de privilégio do DBA incluem comandos para conceder e revogar privilégios para contas individuais de usuários ou de grupos de usuários, e comandos para a realização dos seguintes tipos de ações:

1. *Criação de contas*: Cria uma nova conta e senha para um usuário ou um grupo de usuários para habilitar o acesso ao SGBD.
2. *Concessão de privilégio*: Permite ao DBA conceder certos privilégios a certas contas.
3. *Revogação de privilégios*: Permite que o DBA revogue (cancele) certos privilégios que foram concedidos anteriormente a certas contas.

4. *Atribuição de nível de segurança*: Consiste em atribuir as contas de usuários ao nível de classificação de segurança adequado.

O DBA é responsável pela segurança geral do sistema de banco de dados. A ação 1 na lista anterior é utilizada para controlar o acesso ao SGBD como um todo, ao passo que as ações 2 e 3 são usadas para controlar a autorização *discricionária* no banco de dados, e a ação 4 é utilizada para controlar a autorização *obrigatória*.

6.1.3 Proteção de Acesso, Contas de Usuários e Auditoria de Banco de Dados

Sempre que uma pessoa ou um grupo de pessoas precisar acessar um sistema de banco de dados, o indivíduo ou o grupo deve primeiro requisitar uma conta de usuário. Então o DBA criará um novo **número de conta** e **senha** para o usuário se houver uma necessidade legítima de acessar o banco de dados. O usuário deve realizar a **conexão (log in)** no SGBD entrando com o número de conta e a senha sempre que o acesso ao banco de dados for necessário. O SGBD verifica se o número de conta e a senha são válidos; caso sejam, o usuário tem a permissão de usar o SGBD e de acessar o banco de dados. Programas de aplicação também podem ser considerados usuários e podem ser solicitados a fornecer senhas.

Não há dificuldades em manter informações dos usuários do banco de dados e de suas contas e senhas por meio da criação de uma tabela ou um arquivo cifrado com os dois campos *NumeroDeConta* e *Senha*. Essa tabela pode ser facilmente administrada pelo SGBD. Sempre que uma nova conta for criada, um novo registro é incluído na tabela. Quando uma conta for cancelada, o registro correspondente deve ser excluído da tabela.

O sistema de banco de dados também deve manter informação de todas as operações que são aplicadas por um usuário durante cada **sessão de conexão (login session)**, que consiste em uma seqüência de interações que um usuário realiza desde momento de conexão (*log in*) até o momento de desconexão (*log off*). Quando um usuário se conecta, o SGBD passa a registrar o número da sua conta e associá-lo ao terminal a partir do qual ele se conectou. Todas as operações aplicadas a partir daquele terminal são atribuídas à conta do usuário até que este se desconecte. É particularmente importante manter informações das operações de atualização que são aplicadas ao banco de dados de forma que, se o banco for adulterado, o DBA possa descobrir qual usuário o adulterou.

Para manter um registro de todas as atualizações aplicadas a um banco de dados e do usuário específico que aplicou cada atualização, podemos modificar o *log de sistema*. Podemos expandir as entradas do *log* de forma que elas possam incluir o número da conta do usuário e o *ID* do terminal *on-line* que aplicou cada operação registrada no *log*. Se houver alguma suspeita de adulteração no banco de dados, pode-se realizar uma **auditoria de banco de dados**, que consiste na revisão do *log* para examinar todos os acessos e as operações aplicadas ao banco de dados durante certo período de tempo. Quando uma operação ilegal ou não autorizada for encontrada, o DBA pode determinar o número da conta utilizada para realizar a operação. Essas auditorias particularmente importantes em bancos de dados sensíveis que são atualizados por muitas transações e usuários, como bancos de dados bancários que são atualizados por muitas caixas. Um *log* de banco de dados que é utilizado principalmente para propósitos de segurança é às vezes chamado **audit trail (pista para auditoria)**.

6.2 Controle de Acesso Discrecional baseado na Concessão e na Revogação de Privilégios

O método típico de imposição de **controle de acesso discrecional** em um sistema de banco de dados é baseado na concessão e na revogação de privilégios. Vamos considerar os privilégios no contexto de um SGBD relacional. Muitos SGBDs relacionais atuais usam alguma variação dessa técnica. A principal idéia é incluir sentenças na linguagem de consulta que permitam ao DBA e aos usuários selecionados concederem e revogarem privilégios.

6.2.1 Tipos de Privilégios Discrecionais

Usaremos aqui as palavras *usuário* ou *conta* indistintamente no lugar de *identificador de autorização*. O SGBD deve oferecer acesso seletivo a cada relação do banco de dados baseando-se em contas específicas. As operações também podem ser controladas; assim, possuir uma conta não necessariamente habilita o possuidor a todas as funcionalidades oferecidas pelo SGBD. Informalmente existem dois níveis para a atribuição de privilégios para o uso do sistema de banco de dados:

- O *nível de conta*: Nesse nível, o DBA estabelece os privilégios específicos que cada conta tem, independentemente das relações no banco de dados.
- O *nível de relação* (ou tabela): Nesse nível, o DBA pode controlar o privilégio para acessar cada relação ou visão individual no banco de dados.

Os privilégios no **nível de conta** se aplicam às capacidades providas para a própria conta e podem incluir o privilégio CREATE SCHEMA ou CREATE TABLE para criar um esquema ou uma relação base; o privilégio CREATE VIEW; o privilégio ALTER, para aplicar mudanças no esquema, como adicionar ou remover atributos das relações; o privilégio DROP, para excluir relações ou visões; o privilégio MODIFY, para incluir, excluir ou atualizar tuplas; e o privilégio SELECT, para recuperar informações a partir de um banco de dados por meio do uso de uma consulta SELECT. Observe que esses privilégios de conta se aplicam para a conta de maneira genérica. Se uma certa conta não possuir o privilégio CREATE TABLE, nenhuma relação pode ser criada a partir daquela conta.

O segundo nível de privilégios se aplica ao **nível de relação**, sejam elas relações base ou relações virtuais (visões). Na discussão que se segue, o termo *relação* tanto pode se referir a uma relação base quanto a uma visão, a menos que especifiquemos explicitamente uma ou outra. Os privilégios no nível de relação especificam para cada usuário as relações individuais nas quais cada tipo de comando pode ser aplicado. Alguns privilégios também se referem a colunas individuais (atributos) de relações.

A fim de controlar a concessão e a revogação de privilégios para as relações, para cada relação *R* em um banco de dados é atribuída uma **conta de proprietário**, que tipicamente é a que era utilizada quando a conta foi criada. Ao proprietário de uma relação são dados *todos* os privilégios sobre aquela relação. Aquele que mantém a conta de proprietário pode repassar privilégios em quaisquer das relações em que é proprietário para outros usuários por meio da **concessão** de privilégios para as contas

deles. Em SQL os seguintes tipos de privilégio podem ser concedidos para cada relação *R* individual:

- Privilégio SELECT (*retrieval* (recuperação) ou *read* (leitura)) sobre *R*: Proporciona à conta o privilégio de recuperação. Em SQL, dá à conta o privilégio de usar a sentença SELECT para recuperar tuplas a partir de *R*.
- Privilégios MODIFY sobre *R*: Este proporciona à conta a capacidade de modificar as tuplas de *R*. Em SQL esse privilégio é, de forma mais avançada, dividido nos privilégios UPDATE, DELETE e INSERT para aplicar em *R* os comandos SQL correspondentes. Além disso, ambos os privilégios INSERT e UPDATE podem especificar que apenas certos atributos de *R* possam ser atualizados pela conta.
- Privilégio REFERENCES sobre *R*: Este proporciona à conta a capacidade de fazer referência à relação *R* quando estiver especificando restrições de integridade. Esse privilégio também pode ser restrito a atributos específicos de *R*.

Observe que, para criar uma visão, a conta deve ter o privilégio SELECT em *todas as relações* envolvidas na definição da visão.

6.2.2 Especificando Privilégios Usando Visões

Visões é um importante mecanismo de autorização discricionário em seu próprio direito. Por exemplo, se o proprietário *A* de uma relação *R* quiser que uma outra conta *B* seja capaz de recuperar apenas alguns campos de *R*, então *A* pode criar uma visão *V* de *R* que inclua apenas aqueles atributos e, então, conceder SELECT em *V* para *B*. O mesmo se aplica para limitar *B* a recuperar apenas certas tuplas de *R*; uma visão *V'* pode ser criada pela definição da visão por meio de uma consulta que selecione apenas aquelas tuplas de *R* que *A* deseja permitir que *B* acesse.

6.2.3 Revogação de Privilégios

Em alguns casos é desejável conceder um privilégio a um usuário temporariamente. Por exemplo, o proprietário de uma relação pode querer conceder o privilégio SELECT a um usuário para uma tarefa específica e depois revogar aquele privilégio quando a tarefa estiver completada. Por isso, é necessário um mecanismo para a **revogação** de privilégios. Em SQL, um comando REVOKE é incluído com o propósito de cancelar privilégios.

6.2.4 Propagação de Privilégios Usando GRANT OPTION

Sempre que um proprietário *A* de uma relação *R* concede um privilégio sobre *R* para uma outra conta *B*, o privilégio pode ser dado a *B* com ou sem o **GRANT OPTION**. Se o GRANT OPTION é dado, então *B* também pode conceder aquele privilégio sobre *R* para outras contas. Suponha que a *B* seja dado GRANT OPTION por *A* e que, depois, *B* conceda o privilégio sobre *R* para uma terceira conta *C*, também com GRANT OPTION. Dessa maneira, os privilégios sobre *R* podem **propagar** para outras contas sem conhecimento do proprietário de *R*. Se a conta proprietário *A* revogar agora o privilégio

concedido a *B*, todos os privilégios que *B* tenha propagado baseado naquele privilégio devem ser automaticamente revogados pelo sistema.

É possível que um usuário receba certo privilégio a partir de duas ou mais origens. Por exemplo, A4 pode receber um certo privilégio UPDATE *R* de *ambos* A2 e A3. Neste tipo de caso, se A2 revogar esse privilégio de A4, A4 ainda continuará a - o privilégio pelo fato de ter sido agraciado com ele por A3. Se posteriormente A3 revogar o privilégio de A4, este perderá totalmente o privilégio. Por isso, um SGBD que permite a propagação de privilégios deve manter a informação de como todos privilégios foram concedidos para que a revogação de privilégios possa ser feita correta e completamente.

6.2.5 Um Exemplo

Suponha que o DBA crie quatro contas: A1, A2, A3, e A4, e queira que apenas A1 seja capaz de criar relações base; então o DBA deve aplicar o seguinte comando GRANT em SQL:

GRANT CREATETAB TO A1;

O privilégio CREATETAB (criar tabela) dá à conta A1 a capacidade de criar novas tabelas (relações base) no banco de dados é por isso um *privilégio de conta*. Esse privilégio foi parte de versões antigas da SQL, mas agora é deixado que cada implementação individual de sistema o defina.

Para continuar nosso exemplo, suponha que A1 crie as duas relações base EMPREGADO e DEPARTAMENTO mostradas na Figura abaixo; A1 então é o **proprietário** dessas duas relações e por isso possui *todos os privilégios de relação* sobre cada uma delas.

EMPREGADO

NOME	NUMERODOSEGUROSOCIAL	DATANASC	ENDEREÇO	SEXO	SALARIO	NRD
------	----------------------	----------	----------	------	---------	-----

DEPARTAMENTO

NUMEROD	NOMED	NUMSEGUROSOCIAL_GER
---------	-------	---------------------

Esquemas para as duas relações EMPREGADO e DEPARTAMENTO.

A seguir, suponha que a conta A1 queira conceder à conta A2 o privilégio para incluir e excluir tuplas em ambas relações. Entretanto, A1 não quer que A2 seja capaz de propagar esses privilégios para contas adicionais. A1 pode aplicar o seguinte comando:

GRANT INSERT, DELETE ON EMPREGADO, DEPARTAMENTO TO A2;

Observe que a conta proprietário A1 de uma relação automaticamente possui a GRANT OPTION, permitindo-lhe conceder privilégios sobre a relação para outras contas. Entretanto, a conta A2 não pode conceder os privilégios INSERT e DELETE as tabelas EMPREGADO e DEPARTAMENTO, porque a A2 não foi dado o GRANT OPTION no comando anterior.

A seguir, suponha que A1 queira permitir que a conta A3 recupere informações de ambas as tabelas e também seja capaz de propagar o privilégio SELECT para outras contas. A1 pode aplicar o seguinte comando:

GRANT SELECT ON EMPREGADO, DEPARTAMENTO TO A3 WITH GRANT OPTION;

A cláusula WITH GRANT OPTION significa que A3 agora pode propagar o privilégio para outras contas por meio do uso de GRANT. Por exemplo, A3 pode conceder o privilégio SELECT sobre a relação EMPREGADO a A4 aplicando o seguinte comando:

GRANT SELECT ON EMPREGADO TO A4;

Observe que A4 não pode propagar o privilégio SELECT para outras contas porque o GRANT OPTION não foi dado a A4. Agora suponha que A1 decida revogar o privilégio SELECT sobre a relação EMPREGADO de A3; A1 pode aplicar este comando:

REVOKE SELECT ON EMPREGADO FROM A3;

Agora o SGBD deve revogar automaticamente o privilégio SELECT sobre EMPREGADO de A4, também, porque A3 concedeu aquele privilégio a A4, e A3 não tem mais o privilégio.

A seguir, suponha que A1 queira dar novamente a A3 uma capacidade limitada de SELECT sobre a relação EMPREGADO e queira permitir que A3 seja capaz de propagar o privilégio. A limitação é para recuperar apenas os atributos NOME, DATANASC e ENDERECO, apenas para as tuplas com DNO = 5. Dessa forma, A1 pode criar a seguinte visão:

**CREATE VIEW A3EMPREGADO AS
SELECT NOME, DATANASC, ENDERECO
FROM EMPREGADO
WHERE DNO = 5;**

Após a visão ser criada, A1 pode conceder SELECT sobre a visão A3EMPREGADO para A3 como segue:

GRANT SELECT ON A3EMPREGADO TO A3 WITH GRANT OPTION;

Finalmente, suponha que A1 queira permitir que A4 atualize apenas o atributo SALARIO de EMPREGADO; então A1 pode aplicar o seguinte comando:

GRANT UPDATE ON EMPREGADO (SALARIO) TO A4;

O privilégio UPDATE ou INSERT pode especificar atributos em particular que podem ser atualizados ou incluídos em uma relação. Outros privilégios (SELECT, DELETE) não especificam atributos, porque esse tipo de especificação pode ser facilmente controlado por meio da criação de visões adequadas que incluam apenas os atributos desejados e pela concessão dos privilégios correspondentes sobre as visões. Entretanto, como a atualização de visões nem sempre é possível, para os privilégios UPDATE e INSERT é dada a opção de especificar os atributos específicos de uma relação base que podem ser atualizados.

6.3 Controle de Acesso Obrigatório e Controle de Acesso baseado em Papéis para Segurança Multinível

A técnica de controle de acesso discricionário de concessão e revogação de privilégios sobre relações tradicionalmente tem sido o principal mecanismo de segurança para sistemas de banco de dados relacional. Esse é um método tudo ou nada: ou um usuário possui ou não possui um certo privilégio. Em muitas aplicações, uma *política de segurança adicional*, que classifique dados e usuários baseando-se em classes de segurança, é necessária. Essa abordagem, conhecida por **controle de acesso obrigatório**, tipicamente deveria ser *combinada* com os mecanismos de controle de acesso discricionário descritos na Seção 6.2. É importante observar que atualmente a maioria dos SGBDS comerciais oferece mecanismos somente para controle de acesso discricionário. Entretanto, a necessidade de segurança multinível existe em aplicações governamentais, militares e de inteligência, assim como em muitas aplicações industriais e corporativas.

As **classes de segurança** típicas são altamente secretas (*top secret*) (AS), secretas (*secret*) (S), confidenciais (*confidential*) (C) e não confidenciais (*unclassified*) (NC), em que AS é o nível mais alto e NC é o mais baixo.

De uma forma geral, os mecanismos de controle de acesso obrigatório impõem segurança multinível, pois exigem a classificação de usuários e de valores de dados em classes de segurança e impõem as regras que proíbem o fluxo de informação a partir dos níveis de segurança mais altos para os mais baixos.

6.3.1 Comparação Entre Controle de Acesso Discricionário e Controle de Acesso Obrigatório

As políticas de Controle de Acesso Discricionário (CAD) são caracterizadas por um alto grau de flexibilidade, que as torna adequadas para uma grande variedade de domínios de aplicação. A principal desvantagem dos modelos CAD são as suas vulnerabilidades a ataques maliciosos, como os cavalos de Tróia embutidos em programas de aplicação. A razão é que os modelos de autorização discricionários não impõem nenhum controle sobre como a informação é propagada e usada, tendo sido ela acessada por usuários autorizados a fazê-lo. Políticas obrigatórias, entretanto, asseguram um alto grau de proteção, de certa forma, elas previnem qualquer fluxo ilegal de informação. Portanto, elas são adequadas para aplicações do tipo militar, que exigem um alto grau de proteção. Mas as políticas obrigatórias têm a desvantagem de ser muito rígidas na medida em que exigem uma classificação meticulosa dos sujeitos e dos objetos em níveis de segurança e, portanto, são aplicáveis a muito poucos ambientes. Em muitas situações práticas, as políticas discricionárias são as preferidas porque oferecem melhor relação custo-benefício entre segurança e aplicabilidade.

6.3.2 Políticas de Controle de Acesso para E-Commerce e Para a Web

Os ambientes de comércio eletrônico (**E-commerce**) são caracterizados por quaisquer transações feitas eletronicamente. Elas requerem políticas pormenorizadas de controle de acesso que vão além dos SGBDs tradicionais. Em ambientes convencionais de banco de dados, o controle de acesso é realizado geralmente usando um conjunto de autorizações determinadas por funcionários de segurança ou por usuários de acordo com

algumas políticas da segurança. Um paradigma tão simples não é adequado para um ambiente dinâmico como o *e-commerce*. Além disso, em um ambiente de *e-commerce*, os recursos a serem protegidos não são somente dados tradicionais, mas também conhecimento e experiência. Tais peculiaridades exigem mais flexibilidade na especificação de políticas de controle de acesso. O mecanismo de controle de acesso deve ser bastante flexível para dar suporte a um amplo espectro de objetos heterogêneos a serem protegidos.

Um segundo requisito relacionado é o suporte para o controle de acesso baseado em conteúdo. Esse controle permite expressar políticas de controle de acesso que levam em consideração o conteúdo do objeto a ser protegido. A fim de dar suporte ao controle de acesso baseado em conteúdo, as políticas de controle de acesso devem permitir a inclusão de condições baseadas no conteúdo do objeto.

Um terceiro requisito é relacionado à heterogeneidade dos sujeitos, que exigem políticas de controle de acesso baseadas nas características e nas qualificações do usuário em vez de características muito específicas e individuais (por exemplo, identificadores de usuários). Uma solução possível, para melhor levar em consideração os perfis de usuários na formulação de políticas de controle de acesso, é dar suporte à noção de credenciais. Uma **credencial** é um conjunto de propriedades referentes a um usuário que são relevantes para propósitos de segurança (por exemplo, idade, posição dentro da organização). Por exemplo por meio do uso de credenciais, podem-se formular, de maneira simples, políticas como “Apenas a equipe permanente com cinco ou mais anos de serviço pode acessar documentos relacionados aos estagiários do sistema”.

Acredita-se que a linguagem XML possa ter um papel chave no controle de acesso para aplicações de *e-commerce*. A razão é que a XNÍL está se tornando uma linguagem de representação comum para o intercâmbio de documentos pela *Web*, e também está se tornando a linguagem para o *e-commerce*. Portanto, por um lado, há a necessidade de tornar as representações em XML mais seguras, fornecendo mecanismos de controle de acesso especificamente ajustados para a proteção de documentos XML; por outro, as informações de controle de acesso (ou seja, políticas de controle de acesso e credenciais de usuário) podem ser expressas por meio do uso do próprio XML. O *Director Service Markup Language* fornece uma base para isso: um padrão para a comunicação com os serviços de diretório que serão responsáveis pelo fornecimento e pela autenticação de credenciais de usuários. A apresentação uniforme de ambos, objetos a serem protegidos e políticas de controle de acesso, podem ser aplicada às próprias políticas e credenciais. Por exemplo, algumas propriedades de credencial (como o nome do usuário) podem ser acessíveis para todos, ao passo que outras propriedades podem ser visíveis apenas para uma classe restrita de usuários. Além disso, o uso de uma linguagem baseada em XML para a especificação de credenciais e de políticas de controle de acesso facilita a submissão segura de credenciais e a exportação de políticas de controle de acesso.

6.4 Criptografia e Infra-Estruturas de Chave Pública

Os métodos anteriores, a despeito de serem medidas fortes, podem não ser capazes de proteger os bancos de dados contra algumas ameaças. Suponha que estamos transmitindo dados, e que estes caiam em mãos de algum usuário ilegítimo. Nessa situação, pelo uso da criptografia, podemos disfarçar a mensagem de modo que,

mesmo se a transmissão for desviada, ela não seja revelada. Cifrar é um meio de manter os dados seguros em um ambiente inseguro. Cifrar consiste da aplicação de um **algoritmo de criptografia** para os dados usando alguma **chave de criptografia** preestabelecida. Os dados resultantes precisam ser decifrados utilizando uma **chave de decryptografia** para recuperar os dados originais.

6.4.1 Os Dados e os Padrões Avançados de Criptografia

O Padrão de Criptografia de Dados (*Data Encryption Standard* — DES) é um sistema desenvolvido pelo governo dos EUA para uso do público em geral. Ele tem sido amplamente aceito como um padrão de criptografia tanto nos Estados Unidos quanto no exterior. O DES pode proporcionar a criptografia ponto-a-ponto no canal entre o remetente A e o destinatário B. O algoritmo DES é uma combinação cuidadosa e complexa de dois dos blocos fundamentais de construção de criptografia: substituição e permutação (transposição). O algoritmo deriva sua força da aplicação repetida dessas duas técnicas em um total de 16 ciclos. O texto puro (*plaintext* — a forma original da mensagem) é cifrada em blocos de 64 bits. Embora a chave tenha o tamanho de 64 bits, de fato, a chave pode ser qualquer número de 56 bits. Após ter questionado a adequação do DES, o National Institute of Standards (NIST) apresentou os Padrões Avançados de Criptografia (*Advanced Encryption Standards* — AES). Esse algoritmo tem um tamanho de bloco de 128 bits, comparado com o tamanho do bloco do DES de 64 bits, e pode utilizar chaves de 128, 192 ou 256 bits, comparados com a chave de 56 bits do DES. O AES introduz mais possibilidades de chaves, comparado com o DES, e, assim, leva um tempo muito mais longo para ser quebrado.

6.4.2 Criptografia de Chave Pública

Em 1976 Diffie e Hellman propuseram um novo tipo de sistema de criptografia, o qual chamaram de **criptografia de chave pública**. Os algoritmos de chave pública são baseados em funções matemáticas em vez de em operações sobre modelos de bits. Eles também envolvem o uso de duas chaves separadas, contrastando com a criptografia convencional que usa apenas uma chave. O uso de duas chaves pode ter consequências profundas nas áreas de confidencialidade, distribuição de chave e autenticação. As duas chaves utilizadas para a criptografia de chave pública são chamadas **chave pública** e **chave privada**. Invariavelmente, a chave privada é mantida secreta, porém ela é chamada de *chave privada* em vez de *chave secreta* (a chave usada na criptografia convencional) para evitar confusão com a criptografia convencional.

O esquema, ou infra-estrutura, de criptografia de chave pública possui seis ingredientes:

1. *Texto puro (plaintext)*: Estes são os dados ou a mensagem legível que alimenta o algoritmo como entrada.
2. *Algoritmo de criptografia*: O algoritmo de criptografia executa diversas transformações no texto puro.
- 3 e 4. *Chaves pública e privada*: Estas são um par de chaves que foram selecionadas de forma que se uma for usada para cifrar, a outra é utilizada para

decifrar. As transformações exatas que são conduzidas pelo algoritmo de criptografia dependem da chave pública ou privada que é fornecida como entrada.

5. *Texto cifrado*: É a mensagem embaralhada produzida como saída. Ela depende do texto puro e da chave. Para dada mensagem, duas chaves diferentes irão produzir dois textos cifrados diferentes.

6. *Algoritmo de decryptografia*: Este algoritmo aceita o texto cifrado e a chave correspondente, bem como produz o texto puro original.

Conforme o nome sugere, a chave pública do par é tornada pública para outros a usarem, ao passo que a chave privada é conhecida apenas por seu proprietário. Um algoritmo de criptografia de chave pública de propósito geral se baseia em uma chave para cifrar e em uma outra chave diferente, porém relacionada, para decifrar. Os passos essenciais são os seguintes:

1. Cada usuário gera um par de chaves para serem usadas para cifrar e decifrar as mensagens.
2. Cada usuário coloca uma das duas chaves em um registro público ou em outro arquivo acessível. Esta é a chave pública. A chave que a acompanha é mantida privada.
3. Se um remetente deseja enviar uma mensagem privada para um destinatário, o remetente cifra a mensagem utilizando a chave pública do destinatário.
4. Quando o destinatário receber a mensagem, ele ou ela a decifra utilizando a chave privada do destinatário. Nenhum outro receptor pode decifrar a mensagem porque apenas o destinatário conhece a sua própria chave privada.

O Algoritmo RSA de Criptografia de Chave Pública. Um dos primeiros esquemas de chave pública foi apresentado em 1978 por Ron Rivest, Adi Shamir e Len Adleman no MIT e, por causa deles, é chamado de esquema RSA. Desde então, o esquema RSA reinou de maneira suprema como a abordagem para criptografia de chave pública mais amplamente aceita e implementada. O algoritmo de criptografia RSA incorpora os resultados da teoria de números, combinados com a dificuldade de determinação dos fatores primos de um alvo. O algoritmo RSA também opera com a aritmética modular, mod n .

6.4.3 Assinaturas Digitais

Uma assinatura digital é um exemplo do uso de técnicas de criptografia para prover serviços de autenticação em aplicações de comércio eletrônico. Tal como uma assinatura manuscrita, uma assinatura digital é uma maneira de associar uma marca única a um indivíduo por meio de um corpo de texto. A marca deve ser inesquecível, significando que outros sejam capazes de verificar se a assinatura realmente vem da origem.

Uma assinatura digital consiste em uma cadeia de símbolos. Se uma assinatura digital de uma pessoa for sempre a mesma para cada mensagem, então alguém pode facilmente falsificá-la por meio da simples cópia da cadeia de símbolos. Assim,

assinaturas devem ser diferentes a cada uso. Isso pode ser obtido fazendo cada assinatura digital a partir de uma função da mensagem que está sendo assinada, junto com um registro de data e hora. A fim de ser única para cada assinante e à prova de falsificações, cada assinatura digital deve depender também de algum número secreto que seja único para o assinante. Assim, geral, uma assinatura digital à prova de falsificações deve depender da mensagem e de um número secreto único do assinante. O verificador da assinatura, entretanto, não deve precisar conhecer nenhum número secreto. As técnicas de chave pública são as melhores maneiras de criar assinaturas digitais com estas propriedades.